

GOVERNANCE PLANE · V0.1

Agent *Sentinel*

The control plane that gates every AI agent tool call, signs the audit trail, and meters per-BU spend.

Built on Gemini 2.5 Flash + Pro with Cached Content over full policy documents.

TRACK 2 · GOOGLE AI STUDIO

TRACK 1 · SECURITY & GOVERNANCE

SANKAR SUBBAYYA · 2026.05.19 · AI & BIG DATA EXPO · SAN JOSE

The three open questions every CIO has

COMPLIANCE OFFICER

"Who approved this action, and against which policy?"

Today: logs at best. No cited evidence.

CISO

"How do I stop my agent from doing the wrong thing?"

Today: prompt engineering. No enforcement layer.

CFO

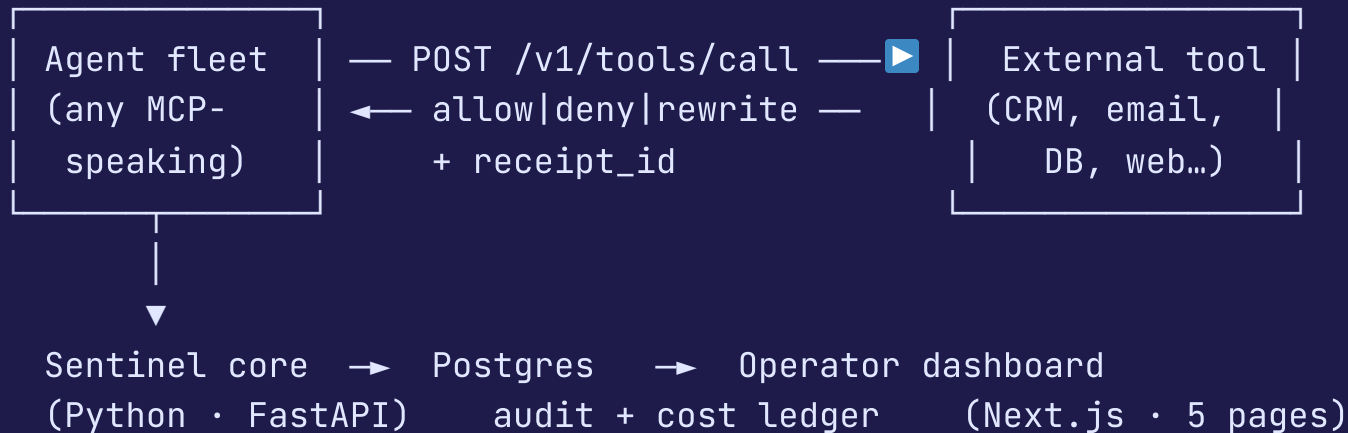
"What is our agent fleet costing each business unit?"

Today: aggregated bill. No attribution.

>70% of F500s have agentic pilots in 2026. <10% are in production. The bottleneck is not model quality — it is operational governance.

What Sentinel does

A single FastAPI process sits between any MCP-speaking agent fleet and the tools they call. Every action flows through a four-stage decision pipeline, becomes a signed audit receipt, and emits a per-business-unit cost event.



Drop-in. Any agent that already speaks MCP `tools/call` is a client — no code changes. **Survives demo conditions.** Runs end-to-end without a Gemini API key via deterministic stub fallbacks.

The four-stage gating pipeline

01

Static engine

<5 ms

Regex denylists, role ACL, refund cap, plaintext PII. No LLM tokens burned on obvious cases.

02

Drift detector

~0 ms

Injection markers in args, tool-vs-declared-goal mismatch, fresh external recipients.

03

Flash gate

<100 ms p95

Gemini 2.5 Flash · `response_schema` · `thinking_budget=0` . Returns GateDecision JSON.

04

Pro escalation

<2 s, ~3-5% of calls

Gemini 2.5 Pro · `cached_content` over whole policy docs. Cited rationale.

Each decision is **hash-chained, HMAC-signed**, and **cites the exact policy version used** — tamper-evident without a blockchain.

Why Gemini — the sponsor-native story

GEMINI 2.5 FLASH · THE GATE

Structured output via

```
response_schema=GateDecision .  
thinking_budget=0
```

for sub-100ms
p95. Every tool call hits Flash.

GEMINI 2.5 PRO · THE REASONER

1M-context window means Pro

consumes **whole policy documents** per
call. **No chunking. No RAG drift.** Cited
rationale.

CACHED CONTENT · THE ECONOMICS

~75% token cost savings on stable
policy bundles. Refreshed every 6h.
Per-call governance becomes
economically viable.

FILES API · THE POLICY LIBRARY

Authoritative policy storage. Multimodal
extraction via Flash. PolicyPipe is 5
modules, ~600 LOC. No LangChain
wrapper hiding the SDK.

This combination — Flash structured output + Pro long-context + Cached Content + Files API — is **uniquely possible on Gemini**.

Live demo (2:30)

t	Beat	What you see
0:00	Setup · three Gemini agents wired through Sentinel	Sales · Finance · Customer Ops live tiles
0:20	Happy path · Sales pulls competitor pricing	● ALLOW · 1 ms · \$0.00065 Sales BU
0:50	Policy violation · Finance emails PII to a vendor	↺ REWRITE · body redacted · cites <i>Data Handling v3.2</i>
1:30	Red team · prompt injection in refund memo	× DENY · drift signal cited · Pro upholds
1:55	Compliance pull · filter receipts by agent + decision	cited timeline with policy chips
2:15	CFO view · BU spend rollup	stacked bar · base vs Gemini · per-BU \$ attribution

Bonus: feed a natural-language brief — *"process refund for C-7733"* — and Gemini picks tools turn-by-turn while Sentinel gates each one.

What's defensible

HASH-CHAINED, HMAC-SIGNED RECEIPTS

Per-agent chain — `prev_hash` → `self_hash`. Rewriting one row invalidates every later row. Tamper-evident **without** a blockchain.

DRIFT DETECTION BEFORE FLASH

Cheap signal — injection markers + tool-vs-declared-goal — escalates the indirect-prompt-injection case to Pro instead of letting Flash decide alone.

PER-BU COST METER

One `cost_event` per gated call, base + Gemini split. CFO chargeback ledger is out of the box, not a Phase-2 ask.

STUB-MODE RESILIENCE

Both Flash and Pro have deterministic fallbacks. Demo correctness **does not depend on a live API call**. Stub Pro never weakens a Flash deny.

FLASH P95

< 100 ms

verified · stub & live

PRO ESCALATION

3-5%

of total calls

PER-CALL COST

< \$0.001

amortized · Cached Content

POLICYPIPE

~600 LOC

no chunking · no vector DB

Three buyers, one architecture

Stakeholder	Their pain	Their surface	Evidence in the receipt
Compliance Officer	"Prove enforcement happened in real time."	<code>/receipts</code> · filterable cited timeline	<code>policy_versions_used</code> , <code>self_hash</code> , <code>signature</code>
CISO	"Stop indirect prompt injection."	<code>/redteam</code> · synthetic adversarial calls	<code>escalated=true</code> , <code>[drift:<reason>]</code> in rationale
CFO	"Charge agent spend back to BUs."	<code>/cost</code> · stacked \$ per BU, 1/7/30-day window	<code>cost_event {bu, base, gemini, total}</code>

Three slides for three buyers in the deck of every CIO meeting we'll walk into. **One Gemini-native architecture serves all of them.**

Roadmap · Phase 2

NATIVE FRAMEWORK ADAPTERS

LangGraph · CrewAI · Anthropic Agent SDK · Google ADK. Today: any MCP-speaking agent. Tomorrow: zero-config for the top four agent frameworks.

MULTI-REGION REPLICATED LEDGER

Document HA path now; ship replicated Postgres + read replicas. Demo is single-region single-instance by design.

CUSTOMER-MANAGED KEYS (KMS)

Receipts signed today with a Sentinel-controlled HMAC key. Phase 2: customer KMS-rotated keys for FedRAMP / SOC 2 paths.

ON-CHAIN RECEIPT ANCHORING (OPTIONAL)

Hash the receipt-chain root, anchor it on Circle Arc / Ethereum. **Builds on our Arc/Circle nanopayment work** (*ARC_DataPiper, Midstream*).

Plus: policy authoring UI · Slack/Teams compliance queries · multi-policy conflict detection.

QUICKSTART · < 90 SECONDS

Try it *now*.

Cloudflare for AI agents — built on Gemini.

All six demo beats verified end-to-end. Stub-mode fallback so a missing API key never blocks the demo.

```
git clone https://github.com/SankarSubbayya/agent_sentinel
cd agent_sentinel && createdb agent_sentinel
uv sync && uv run sentinel init-db
uv run sentinel serve --port 8088 # gateway
cd dashboard && npm i && PORT=3030 npm run dev # dashboard
uv run sentinel demo run # 2:30 walkthrough
```